Roles & When to Engage Product Security

Product security is not one team's job. Your product security team can't see every design decision, customer conversation or supplier notice. The program works when each role knows its part and when to hand over.

Who does what

A **typical** split; your own procedure defines the real one (in a small company one person may cover three rows). Most problems happen at **hand-offs**, when information one role holds never reaches the role that needs it.

ROLE	BEFORE RELEASE	AFTER RELEASE	WATCH FOR
Product owner	Makes security a product requirement, with room in roadmap and budget.	Prioritizes fixes and updates; owns end-of-support decisions.	Connected features added without review; “we'll fix it next release”.
Program or project manager	Schedules security activities as real deliverables.	Plans patch releases; coordinates cross-team response.	Security testing squeezed into the last week or moved “after launch”.
Engineering	Designs, builds and tests security controls; keeps the component list accurate.	Investigates and fixes vulnerabilities; builds and validates updates.	Debug access, default passwords or test accounts left in; unreviewed components.
Product security	Sets the method; leads threat modeling and risk assessment; reviews designs and submission content.	Monitors vulnerabilities; runs the PSIRT; coordinates disclosure and advisories.	Being brought in late as a final gate, when changes cost most.
Quality and regulatory	Builds security into design controls and risk management; owns the submission.	Runs complaints and corrective action; decides on regulator reports and field actions.	Complaints closed as “no fault found” without asking “could this be security?”
Clinical or medical affairs	Judges clinical impact of security risks, and whether controls fit workflow and emergencies.	Assesses patient risk of a vulnerability and its fix; shapes clinician and patient messages.	Controls that slow care in an emergency.
Service and support	Explains field needs (remote access, service tools) so they're designed securely.	Often first to hear of odd behavior; installs updates; decommissions returned units.	Shared service passwords, unofficial remote tools, resetting a device before reporting it.
Sales and customer teams	Bring customer security requirements in early: questionnaires, contracts, tenders.	Share approved documentation and advisories; route questions and reports.	Promising fix dates nobody agreed; answering questionnaires from memory.
Supply chain, procurement	Build security into supplier selection and contracts: component lists, flaw notification, support life.	Pass supplier security notices on quickly; manage component end of life.	Substitute parts or supplier changes nobody else hears about.

Patient safety lens. Security decisions are often clinical: taking FlowGuard pumps off the network, or updating a CardiaPace implant, affects patients. Clinical colleagues belong in the room.

Map your program with a RACI chart: who is **R**esponsible, **A**ccountable (exactly one role), **C**onsulted and **I**nformed for each activity? Gaps become visible. Start from the program RACI template.

Everyday habits

Ask the security question.
In every design review: does this change how the product connects, what it trusts or what data it holds?

Keep the inventory honest.
Report component, version and supplier changes, so a new vulnerability can be checked in hours.

No secrets in the wrong place.
Keep passwords, keys and patient data out of tickets, chat, email and code.

No “temporary” back doors.
Track debug ports, test accounts and default passwords; remove them before release.

Answer from approved sources.
Use published security documents; route new questions. Never guess or promise a fix date.

Take field signals seriously.
An odd connection, unknown setting or strange returned unit is worth a message. Report; don't reset.

When to engage your product security team

Your product security team would rather hear about ten things that turn out fine than miss one that doesn't.

DESIGN AND BUILD

Changes to the product

- [ ] A new interface: Wi-Fi, Bluetooth, USB, cloud, app, service port.
- [ ] A new or changed third-party or open-source component, even a version upgrade.
- [ ] A change to security controls: logins, permissions, encryption, updates.
- [ ] New data types or cloud services.

Usually: **early**, at the next design review

CUSTOMERS AND FIELD

Signals from outside

- [ ] A customer security questionnaire, tender or contract clause.
- [ ] A suspected vulnerability, from anyone.
- [ ] Odd field behavior: unexpected traffic, unknown settings.
- [ ] A complaint that might be security-related.

Usually: **now**, the same day

LIFECYCLE

Decisions about the future

- [ ] End-of-support decisions for the product or anything in it, such as its operating system.
- [ ] Operating-system or platform upgrade plans.
- [ ] Changes to remote service access: tools, people, partners, ways in.

Usually: **early**, at the next planning milestone

Now (the same day)

Anything suggesting a product may be vulnerable today: a suspected vulnerability, odd field behavior, a possibly security-related complaint, a supplier flaw notice. Questionnaires too: they have deadlines.

Early: next design review

Planned changes to interfaces, components, data, cloud or remote access, and end-of-support dates, **before the design is settled**. A "minor library update" still changes the SBOM.

No need

Changes that can't affect how the product resists or recovers from attack, such as brochure photos. When in doubt, ask: it costs one message.

Reporting a suspected vulnerability or incident

You don't need to know whether it's a **vulnerability** (a weakness someone could exploit) or an **incident** (one that is, or may have been, exploited), or whether it's real. Notice and report.

1. **Report internally right away**, usually to your PSIRT (product security incident response team), and to the complaint process if a customer reported it. No channel? Tell your manager the same day. Note product, version, what, where, when, who.
2. **Don't investigate or test on your own.** It can disrupt therapy and destroy evidence.
3. **Preserve information.** Keep emails, screenshots and logs. Don't reset, wipe or ship back a device until the team says so.
4. **Keep it confidential.** Thank the reporter and say it has been passed on. Don't confirm, deny, debate or promise dates.

Patient safety first. If a patient may be affected now, follow your complaint and adverse-event process immediately and report the security angle in parallel. Never "test the theory" on a device connected to a patient.

If an outside researcher contacts you: thank them, point them to your company's published **vulnerability disclosure policy (VDP)**, and pass everything to your PSIRT the same day. Researchers who report are helping. The goal is **coordinated vulnerability disclosure**: the fix and the news arrive together.

What typically happens next (your PSIRT coordinates the other teams)

1. Intake — Logs the report, acknowledges it, asks for details. →

2. Triage — Is it real? Which products and versions? →

3. Assess risk — How exploitable? What could happen to patients? →

4. Fix and communicate — Update or mitigate; tell customers, regulators if needed, and the reporter.

You may not hear every detail afterward: information is need-to-know until a fix is ready. That is normal, not a sign your report was ignored.

This week, find and write down two things. To adapt these triggers for your team, use the engagement checklist template.

Our internal channel for suspected product vulnerabilities: _____

Our published vulnerability disclosure policy: _____

CardiaPace and FlowGuard are fictional devices. Training material, not legal or regulatory advice.